Wonderland שלב 2

בשלב הזה עבדתי ב-static analysis בלבד: לא הרצתי את Wonderland.exe ולא שיניתי קוד, רגיסטרים או זיכרון. בהמשך לשלב 1 התחלתי מחלון ה-Strings ב-IDA, מצאתי את מחרוזת הפתיחה ("Welcome to Wonderland...") ועקבתי דרך ה - Xref שלה ל - main. ב - main יש switch case שמנתב לכל שלב לפי המספר שמכניסים, וראיתי שה- case של שלב 2 קורא לפונקציה `sub_401330`. נכנסתי לפונקציה `sub_401330` כדי להבין מה היא עושה. ראיתי שהיא קוראת מחרוזת מהמשתמש עם `fgets`, ואז רצה עליה בלולאה שמתקדמת ב-4 בכל סיבוב, וכל 4 בתים עוברים פעולת XOR עם הקבוע `0x41524241`. בסוף הלולאה היא משווה את התוצאה למחרוזת הקבועה `"into the rabbit hole"` עם `strncmp`, ואם הן יוצאות שוות מקבלים "Correct! you may enter"..".



הפונקציה sub_401330: לולאת ה-XOR וה-strncmp

הבנתי שה-XOR נעשה על dword שלם בכל פעם, וכיוון שהמחשב עובד בשיטת Little Endian הבתים של `0x41524241` בזיכרון הם `41 42 52 41`. כלומר לכל בית במחרוזת עושים XOR לפי המיקום שלו במודולו 4, עם המפתח: `0x41, 0x42, 0x52, 0x41`. מכאן הדרך לפתרון הייתה מהירה. XOR זו פעולה הפיכה, אז כל מה שהיה צריך זה לקחת את `"into the rabbit hole"` ולעשות לכל תו XOR עם הספרה המתאימה לו. כתבתי קוד פייתון קצר:

```
s = "into the rabbit hole"
key = [0x41, 0x42, 0x52, 0x41]
password = ""
i = 0
while i < len(s):
    password += chr(ord(s[i]) ^ key[i % 4])
    i += 1
print(password)
```

והסיסמה שיצאה היא:

```
(,&.a6:$a03##+&a)->$
```

הקטע באסמבלי שעליו התבססתי

זה הלב של הפונקציה: לולאת ה-XOR על dword שלם, וההשוואה מול המחרוזת הקבועה.

```
loc_4013AE:
    mov   edx, [ebp+var_4]
    add   edx, 3
    cmp   edx, [ebp+var_C]                ; ממשיכים כל עוד נשארו לפחות 4 בתים
    jnb   short loc_4013D5
    mov   ecx, dword ptr [ebp+eax+Buffer]
    xor   ecx, 41524241h                  ; XOR על 4 בתים בבת אחת
    mov   dword ptr [ebp+edx+Buffer], ecx
...
loc_4013D5:
    mov   [ebp+Str], offset aIntoTheRabbitH_0 ; "into the rabbit hole"
    call  ds:strncmp
    test  eax, eax
    jz    short loc_401413                 ; אם התוצאה שווה -> "Correct"
```

ה-`add` שמקדם את המונה ב-4 בכל סיבוב הוא מה שגרם לי להבין שה-XOR עובד על 4 בתים בכל פעם, ומכאן הגעתי למפתח `41 42 52 41`.

איך אימתתי

עבדתי static בלבד ולא הרצתי את Wonderland.exe. כדי לוודא שהסיסמה נכונה לקחתי את הפלט של הסקריפט ועשיתי לו שוב XOR עם אותו מפתח, וקיבלתי בחזרה בדיוק `into the rabbit hole`, שזו המחרוזת שה-`strncmp` משווה מולה. אם ההיפוך מחזיר את מחרוזת היעד, סימן שהקלט שלי הוא מה שהתוכנית מחפשת.